

Lab 07: Auditing a Network Application Server

In this lab, you will exploit a server containing a memory disclosure vulnerability. Its purpose is to protect a secret message shared only with those knowing the login credentials. An authenticated user may get and set the secret message.

Purpose

To practice using static and dynamic tools to discover and exploit a security vulnerability in a server application binary.

Procedure

You will need access to the following materials:

- A computer with a working, licensed copy of Linux, macOS, or Windows.
- A suite of reverse-engineering tools likely consisting of at least one static and one dynamic analysis tool, as well as a network monitoring tool.
- A working installation of Python 2 for your OS – Python 2.7 required for Windows.
- A copy of this lab's vulnerable server binary and authentication stub for your OS.
- A copy of this lab's corresponding client-side API and functional tests (provided in Python).

To use the API, ensure the server is running, and instantiate a client in Python:

```
client = TestClient("localhost", 8764)
```

where "localhost" is the address of the server, and 8764 is the port. Please note the following port numbers depending on the platform you choose:

	Windows	Linux	macOS
32-bit	8732	7632	6532
64-bit	8764	7664	6564

The client then authenticates:

```
client.authenticate("johndoe", "password")
```

If the credentials are accepted, the command completes, otherwise an exception is raised. The client may now get and set the secret message, then close the connection:

```
secret = client.get_secret()
print secret
client.set_secret("Hello_to_all_my_secret_friends!")
client.close()
```

The following guide questions may help you along:

1. What is the general format of requests and replies? You may want to look up documentation for Python's struct package.
2. Take a look at the numbering of the request types. Does one seem to be missing?
3. Explore the missing request number. What does it do?
4. Does that request follow the same format as the others?
5. How might you take advantage of the extraneous field? You may want to read about heaps.
6. Perhaps try experimenting with multiple clients connected. Can one client read another client's credentials? How?
7. How might you increase your chances of success?

Now, prepare an exploit for this vulnerability. You should be able to accomplish this by modifying the provided client API code. You will use it to steal the secret from my server over the Internet. I'll have a server running with a client that repeatedly logs in and sets the secret. You must steal the credentials and retrieve the secret message.

The servers are all hosted at `reclass.ddns.net`. All six should be accessible at their designated port numbers.

Tips and Caveats

- If you are having trouble connecting, please let me know, and I'll take a look.
- If you are having trouble exploiting, you might just try one of the other OSes – sometimes you get lucky.
- Please be respectful of other groups; do not intentionally prevent others from completing the assignment.
- If you browse to `reclass.ddns.net`, you will likely find my router login. THIS IS NOT PART OF THE ASSIGNMENT. You are not permitted to scan, enumerate, probe, etc., or otherwise attempt to break into any resources at `reclass.ddns.net` other than those designated for this lab. Those permitted resources consist solely of the six processes listening on the TCP ports given in the table above.

Report

Completion of this lab must be substantiated by a report prepared by the group. It is up to each group to divide its responsibilities fairly. The report should provide sufficient detail that another person could verify your work.

Please include an archive of any source code and resulting binaries, if applicable, in your electronic submission. Please also include the following in your report:

1. The credentials stolen from `reclass.ddns.net`
2. The secret stored at `reclass.ddns.net`

Grading

The report should describe the purpose of the lab, the procedure, any assumptions, problems, or hypotheses, and the final results. Mostly, I'll be looking for a proper problem statement, a structured procedure, and for a reasonably correct solution demonstrated by your results.

The proof of success is in obtaining the secret message, so please remember to include it in your report. Please provide your exploit code (e.g., modified client Python code) as well.

This lab is due midnight next week.

Rubric

points	Accomplishment
3	Report is well-written (organized, detailed, illustrative)
2	Report provides correct description of the exploitable message
2	Report correctly explains the vulnerability and how to exploit it
1	The provided exploit code follows the exploit process described in the report
1	The stolen credentials for the server at <code>reclass.ddns.net</code> are correct
1	The stolen secret at <code>reclass.ddns.net</code> is correct.